Dossier de cadrage stratégique et gouvernance – PrediCare TPA

Projet de détection de fraude médicale et d'assistant virtuel pour un TPA (tiers payant). Version du 21/10/2026.

1. Périmètre et état du produit

PrediCare TPA comprend une API FastAPI (authentification JWT, endpoint de prédiction de fraude), une base PostgreSQL avec pgvector, un agent RAG local (Ollama) avec cache sémantique, un frontend Streamlit par rôle (assuré, professionnel de santé, gestionnaire, administrateur) et un workflow n8n d'alerte.

État constaté lors des tests de la version B : l'authentification, les rôles, l'assistant RAG (369 extraits indexés) et le workflow n8n fonctionnent. Le modèle de fraude n'est pas déployé (fichiers du modèle absents, l'endpoint de prédiction renvoie une erreur 500), et douze tables du schéma ne contiennent que la colonne d'identifiant. Les sections ci-dessous distinguent donc ce qui est **en place** de ce qui est **à faire**.

2. Analyse TCO et ROI (FinOps)

Avertissement : tous les montants ci-dessous sont des **hypothèses de travail**, non des mesures. Ils doivent être remplacés par les valeurs réelles du TPA avant toute décision.

2.1 Hypothèses

Poste	Hypothèse
Horizon	3 ans
Développement et intégration (une fois)	10 000 €
Serveur local (une fois)	3 000 €
Électricité et connectivité	25 € par mois
Cloud : LLM via API	200 € par mois (environ 20 000 requêtes à 0,01 €)
Cloud : base gérée et hébergement	140 € par mois
Remboursements annuels du TPA	2 000 000 €
Part de fraude estimée	3 % des remboursements

Poste	Hypothèse
Taux de détection du modèle	50 % (non validé, modèle absent)

2.2 Comparaison sur 3 ans

	Architecture locale (retenue)	Alternative cloud
Développement	10 000 €	10 000 €
Matériel	3 000 €	0 €
Exploitation (36 mois)	900 €	12 240 €
Total 3 ans	**13 900 €**	**22 240 €**

L'architecture locale évite les coûts récurrents d'API et d'hébergement, et garde les données de santé sur site, ce qui sert aussi la conformité (section 3). Elle suppose une compétence d'exploitation interne et un matériel capable de faire tourner le LLM (les premières réponses sont lentes sur processeur seul : 70 s à froid, 17 s ensuite lors des tests).

2.3 ROI illustratif

Gain annuel estimé = remboursements × part de fraude × taux de détection = 2 000 000 × 3 % × 50 % = **30 000 € par an**, soit 90 000 € sur 3 ans.

- ROI sur 3 ans (architecture locale) = (90 000 − 13 900) / 13 900 ≈ **5,5**
- Retour sur investissement en environ **5,6 mois** (13 900 / 2 500 € de gain mensuel)

Ce calcul est **très sensible** au taux de détection et à la part de fraude réelle. Il ne tient pas compte du coût des faux positifs (temps de vérification des gestionnaires). Il ne pourra être confirmé qu'après déploiement du modèle et mesure de ses performances.

3. Conformité RGPD

Principe	Mise en œuvre	État
Pseudonymisation	Les données de soins sont rattachées à un pseudonyme (ASS-001) ; le dashboard et le gestionnaire n'affichent jamais de nom. Une table d'identités séparée est prévue dans le schéma de l'équipe.	Pseudonymes en place dans les données de démonstration ; table d'identités **à implémenter**
Minimisation	Le modèle reçoit des indicateurs numériques (montants, délais), pas d'identité.	Conçu ainsi, à confirmer avec la liste des variables
Données sensibles (art. 9)	Données de santé : base légale et mesures renforcées à documenter.	À formaliser
Décision automatisée (art. 22)	Le modèle ne rejette aucune facture seul : il produit un score et une explication, le gestionnaire décide.	Principe retenu
Droits des personnes	Accès, rectification, effacement par le pseudonyme et la table d'identités.	À outiller
Sécurité et traçabilité	Voir section 6 ; une table de journal d'audit est prévue.	Partiel
Conservation	Durées par catégorie de données à fixer.	À définir
Analyse d'impact (AIPD)	Obligatoire pour des données de santé traitées à grande échelle.	À réaliser
Hébergement	Traitement 100 % local, aucun transfert vers un cloud tiers.	En place

Le droit applicable (RGPD si des résidents de l'UE sont concernés, loi malgache sur les données personnelles dans tous les cas) doit être confirmé par un juriste.

4. EU AI Act

Classification : l'évaluation de l'accès aux prestations et services essentiels figure parmi les usages à haut risque du règlement. La détection de fraude sur des remboursements de santé peut s'en rapprocher. La qualification exacte relève d'un avis juridique ; **par prudence, le système est traité comme à haut risque**.

Exigence	Mesure	État
Gestion des risques	Registre des risques (section 7)	À tenir à jour
Gouvernance des données	Jeu d'entraînement documenté, contrôle des biais	À documenter
Documentation technique	Ce dossier, le guide d'exploitation, l'API documentée (Swagger)	Partiel
Journalisation	Prédictions enregistrées avec score et explication (table des prédictions)	En place côté API
Transparence	Les réponses de l'assistant indiquent qu'elles sont générées par un LLM et listent les outils utilisés.	En place
Supervision humaine	Le gestionnaire valide toute décision ; seuil d'alerte réglable.	Principe retenu
Robustesse et exactitude	Tests mesurés : un plafond erroné a été produit par le LLM local (200 000 000 Ar au lieu de 2 000 000 Ar).	**Limite constatée**

L'assistant virtuel relève de l'obligation d'information (l'utilisateur doit savoir qu'il échange avec une IA).

5. Audit d'équité du modèle

Résultats chiffrés : non disponibles. Le modèle de fraude n'est pas déployé, aucune mesure n'a donc été faite. Cette section fixe la méthode à appliquer dès que le modèle sera livré.

- **Groupes comparés :** formule (ESSENTIEL, CONFORT, PREMIUM), catégorie de soins, type et zone de prestataire, ancienneté d'adhésion. Les caractéristiques protégées (sexe, âge, origine) ne sont pas des variables du modèle, mais doivent être testées comme proxys possibles.

- **Indicateurs :** taux d'alerte par groupe, rapport entre le plus faible et le plus élevé (seuil indicatif de 0,8), écart des taux de faux positifs et de faux négatifs par groupe (nécessite des étiquettes de fraude confirmées).
- **Contrôles :** examen des variables les plus influentes (valeurs SHAP déjà calculées par l'API), test de stabilité selon le seuil, revue humaine d'un échantillon d'alertes.
- **Fréquence :** avant mise en production, puis à chaque réentraînement.

6. Mécanismes de sécurité

6.1 En place

Mécanisme	Détail
Authentification	Jeton JWT (HS256) émis par `/auth/login`, mots de passe hachés avec bcrypt
Rôles	admin, gestionnaire, professionnel, assuré ; navigation du frontend différente par rôle
Limitation des échecs	Blocage après 5 échecs de connexion côté frontend
Garde-fous du LLM	Module de garde-fous, outils restreints, compte de base en lecture seule pour l'agent
Cloisonnement	Services dans un réseau Docker ; seul le nécessaire exposé
Localité des données	Aucun appel à un service cloud payant

6.2 Failles et corrections à prévoir

Constat	Correction
L'endpoint `/predict/` n'exige aucun jeton alors qu'il écrit en base	Le protéger par la dépendance d'authentification et restreindre par rôle
Seuils de fraude (0,5 et 0,8) codés en dur, `FRAUD_THRESHOLD` non lu	Lire la configuration
Secrets de démonstration dans `.env` (clé JWT, mot de passe n8n)	Les remplacer par des valeurs fortes et ne pas les versionner

Constat	Correction
Le frontend se connecte à la base avec le compte administrateur	Utiliser un compte dédié à droits limités
Les rôles ne sont contrôlés que par le frontend	Contrôler le rôle dans chaque route de l'API
Garde-fou hors sujet insuffisant (l'assistant propose de chercher des recettes)	Refus explicite hors périmètre
Absence de chiffrement du trafic en local	TLS derrière un proxy en production

7. Registre des risques

Risque	Gravité	Mesure
Modèle de fraude absent ou non validé	Élevée	Livraison du modèle, mesure des performances avant tout usage réel
Erreur de chiffre dans une réponse de l'assistant	Moyenne	Citer les sources, vérification humaine, contrôle automatique des montants
Biais ou faux positifs sur certains groupes	Élevée	Audit d'équité (section 5), supervision humaine
Fuite de données de santé	Élevée	Pseudonymisation, droits minimaux, secrets renforcés
Schéma de données incomplet	Élevée	Livraison du schéma complet et d'un jeu de démonstration
Lenteur du LLM local	Faible	Matériel adapté, modèle plus léger, cache sémantique

8. Feuille de route

1. Livrer le modèle de fraude et les noms des variables attendues.
2. Écrire le schéma complet (factures, assurés, contrats, identités) et migrer le frontend des tables provisoires vers ce schéma.
3. Appliquer les corrections de la section 6.2.
4. Mesurer le modèle, réaliser l'audit d'équité et l'AIPD.
5. Remplacer les hypothèses du TCO par des valeurs réelles et réviser le ROI.